

Third Party Vendor Risk Management & Integration Policy

Sector: Financial Services | Country: United States | Risk Level: High

1. Objective

Establish a rigorous framework for evaluating, onboarding, and managing third party solutions in the financial services environment. Ensure that vendor due diligence is not bypassed and that all third party systems undergo mandatory security assessments, regulatory compliance, and mitigate supply chain risks.

2. Scope

Applies to all business units, IT systems, SaaS applications, and external vendors that provide services, software, or data processing for the organization across the United States. Includes all personnel involved in vendor selection, contract negotiation, security assessment, and ongoing monitoring.

3. Policy Statements

- All prospective third party vendors must complete a documented due diligence assessment before any contract is executed.
- Vendor onboarding workflows shall enforce mandatory security controls; any attempt to bypass due diligence must be escalated to the CISO and halted.
- Contracts with vendors must include clauses for data protection, right to audit, breach notification within 72/hours, and compliance with ISO/IEC/27001, NIST CSF, and GDPR requirements.
- Privileged access to vendor provided SaaS platforms shall be limited to necessary functions and reviewed quarterly by the Vendor Risk Management Lead.
- Continuous monitoring of vendor security posture shall be performed at least annually, with risk reassessment triggered by any significant change in service scope or security posture.

4. Procedures

Vendor Onboarding and Due Diligence

Step 1: Initiate vendor request in the Vendor Management System (VMS) and assign a risk rating based on service criticality.

Step 2: Complete the standardized due diligence questionnaire and obtain security assessment reports (e.g., SOC/2, ISO/27001 certification).

Step 3: Review assessment results against policy controls; obtain approval from the CISO and Legal before contract signing.

Step 4: Record all documentation in the VMS and configure initial access controls according to least privilege principles.

Ongoing Vendor Monitoring and Assessment

Step 1: Schedule annual security assessments and request updated attestations from each vendor.

Step 2: Run automated compliance scans against vendor APIs and SaaS integrations to verify configuration drift.

Step 3: Document findings, update the vendor risk register, and require remediation plans for any deficiencies within 30 days.

Step 4: Escalate unresolved high risk issues to the Executive Risk Committee for potential termination.

Incident Response for Third Party Breaches

Step 1: Notify the Vendor Risk Management Lead immediately upon detecting a security incident.

Step 2: Activate the joint incident response plan, collect forensic evidence, and assess impact on personal data per GDPR Art.33.

Step 3: Coordinate with the vendor to remediate the breach, enforce breach notification timelines, and update the risk register.

Step 4: Conduct a post incident review, incorporate lessons learned into policy updates, and report outcomes to senior leadership.

5. Enforcement

Non compliance with this policy will result in remediation actions, possible disciplinary measures up to termination for employees, and may trigger contract termination or legal action against vendors.

6. Governance Structure

Role	Responsibility
Chief Information Security Officer (CISO)	Overall authority for policy approval, enforcement, and alignment with ISO/IEC/27001 and NIST frameworks.
Vendor Risk Management Lead	Manage due diligence processes, maintain the vendor risk register, and oversee continuous monitoring activities.
Legal & Compliance Officer	Ensure contracts embed required regulatory clauses (GDPR, FFIEC, etc.) and oversee legal compliance monitoring.
IT Operations Manager	Implement technical controls for access management, PAM, and integration security for SaaS services.

7. Compliance Control Matrix

Framework	Control ID	Title	Coverage
ISO_27001	5.1	Policies for information security	Addressed in Policy

Framework	Control ID	Title	Coverage
ISO_27001	5.2	Information security roles and responsibilities	Addressed in Policy
ISO_27001	5.15	Access control	Addressed in Policy
ISO_27001	5.16	Identity management	Addressed in Policy
ISO_27001	5.17	Authentication information	Addressed in Policy
ISO_27001	5.23	Information security for use of cloud services	Addressed in Policy
NIST_CSF	CSF-PR.IP-12	Supplier risk management	Addressed in Policy
NIST_SP_800_53	FW-007	AC-2 Account Management	Addressed in Policy
NIST_SP_800_53	FW-008	SI-7 Software, Firmware, and Information Integrity	Addressed in Policy
FFIEC_OUTSOURCING	FFIEC-OT-01	Third Party Due Diligence and Ongoing M	Addressed in Policy
GDPR	Art.5	Principles of personal data processing	Addressed in Policy
GDPR	Art.6	Lawfulness of processing	Addressed in Policy
GDPR	Art.13	Information to be provided to data subjects	Addressed in Policy
GDPR	Art.17	Right to erasure	Addressed in Policy
GDPR	Art.22	Automated individual decision-making	Addressed in Policy
GDPR	Art.25	Data protection by design and by default	Addressed in Policy
NIST_AI_RMF	GOVERN-1.1	AI Risk Governance Policies	Addressed in Policy
NIST_AI_RMF	GOVERN-1.2	Accountability Structures	Addressed in Policy
NIST_AI_RMF	GOVERN-2.1	Organizational AI Risk Culture	Addressed in Policy
NIST_AI_RMF	MAP-1.1	Risk Context Identification	Addressed in Policy
NIST_AI_RMF	MAP-3.1	Stakeholder Impact Assessment	Addressed in Policy
NIST_AI_RMF	MEASURE-1.1	AI Risk Metrics	Addressed in Policy

8. Risk Mitigation Mapping

Risk ID	Risk Type	Mitigation	Severity
RISK-008	Access Control	Implement least-privilege principle, privileged access management (PAM) tools, session recording, and quarterly access reviews.	High
RISK-001	Regulatory	Establish internal AI governance board; adopt international standards (NIST AI RMF, OECD AI Principles) as interim framework.	High
RISK-002	Cyber	Implement adversarial testing, model security reviews, input validation, and continuous monitoring pipelines.	High
RISK-009	Privacy	Encrypt data at rest and in transit, implement breach detection tools, and maintain 72-hour breach notification procedures (GDPR Art.33).	High
RISK-011	Supply Chain	Conduct vendor due diligence, include security requirements in contracts, monitor vendor compliance, and maintain alternative supplier lists.	Medium
RISK-012	Legal	Conduct regulatory mapping annually, engage legal counsel for policy review, and maintain a compliance obligations register.	Medium